

focuses on verified facts to make sure that organisations using the OSSTMM for their own penetration testing methodologies can know they are making fact based decisions.

This framework contains a comprehensive guide for testers to identify security vulnerabilities within a network (and its components) from various potential angles of attack. This methodology relies on the tester's in-depth knowledge and experience, as well as human intelligence, to interpret the identified vulnerabilities and their potential impact within the network. OSSTMM provides five channels to guide organisations to fully extend their security processes and determine how well they actually function. The five channels include:

- *Human security:* How securely humans within an organisation interact and communicate is evaluated operationally, as a means of testing.
- *Physical security:* OSSTMM tests physical security, which is defined as any tangible element of security that takes physical effort to operate.
- *Wireless communications:* Electronic communications, signals and emanations are all considered wireless communications that are part of the operational security testing.
- *Telecommunications:* Whether a telecommunications network is digital or analogue, any communication conducted over the telephone or network lines is tested in OSSTMM.
- *Data networks:* This includes the security testing of electronic systems and data networks that are used for communication or interaction via cable and wired network lines.

OWASP (Open Web Application Security Project)

This is the most recognised standard in the industry. This framework provides a methodology for application penetration testing that can not only identify vulnerabilities commonly found within Web and mobile applications, but also find

the complicated logic flaws that stem from unsafe development practices.

With the help of this methodology, organisations are better equipped to secure their applications – Web and mobile alike – from common mistakes that can have a potentially critical impact on their business. Organisations looking to develop new Web and mobile applications should also consider incorporating this standard during their development phase to avoid introducing common security flaws.

NIST (National Institute of Standards and Technology)

This provides a manual that is best suited to improve the overall cyber security of an organisation. The most recent version, NIST 1.1, places more emphasis on critical infrastructure cyber security. Complying with the NIST framework is often a regulatory requirement for various American providers and business partners. NIST discusses penetration testing in SP800-115. The NIST methodology is less exhaustive than OSSTMM.

PTES (Penetration Testing Execution Standard)

This penetration testing execution standard consists of seven main sections. These cover everything related to a penetration test – beginning with the initial communication and reasoning behind a pen test, right through to the intelligence gathering and threat modelling phases (when testers are working behind the scenes in order to get a better understanding of the tested organisation). PTES also covers vulnerability research, exploitation and post exploitation (when the technical expertise of the testers comes into play and combines with their understanding of the business of the target organisation). Finally, PTES covers the reporting, which captures the entire process, in a manner that makes sense to the customer and provides the most

value to it. The following are the main sections defined by the standard, as the basis for penetration testing execution:

- Pre-engagement interactions
- Intelligence gathering
- Threat modelling
- Vulnerability analysis
- Exploitation
- Post exploitation
- Reporting

ISSAF (Information System Security Assessment Framework)

The ISSAF standard contains an even more structured and specialised approach to penetration testing than the previous standard. These sets of standards enable a tester to meticulously plan and document every step of the penetration testing procedure, from planning and assessment, to reporting and destroying artefacts. This standard caters for all steps of the process. Pen testers who use a combination of different tools find ISSAF especially crucial as they can tie each step to a particular tool. The assessment section, which is more detailed, governs a considerable part of the procedure. For each vulnerable area of your system, ISSAF offers some complementary information, various vectors of attack, as well as possible results when a vulnerability is exploited.

ISSAF breaks the pen testing project into three phases:

- Planning and preparation
- Assessment
- Reporting, clean-up and destroying artefacts

Automated penetration testing

Automated penetration testing plays an important role in a security analyst's arsenal. As part of an organisation's overall security strategy, automated penetration tests quickly evaluate the existing security maturity of its technical infrastructure. However, one cannot solely rely on automated penetration tests, and they must be monitored by the internal security team.